SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration:90min **Total Marks: 50**

Code of Conduct:

I **J. SAI DHEERAJ (192311191)** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: **J.SAI DHEERAJ**

Report Analysis

Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. (20 Marks)

Introduction

Nmap (Network Mapper) is a network scanning tool used to identify open ports, running services, service versions, and operating systems on a target system. In this case, the target IP address is 192.168.1.10, and the scan identified HTTP (80), SSH (22), and MySQL (3306) as open ports.

A. Analysis of Identified Services and Security Risks

Port	Service	Security risks
22	SSH	Weak passwords, brute-force attacks, outdated SSH versions, and unauthorized remote access.
80	HTTP	Unencrypted communication, session hijacking, web application vulnerabilities, and data interception.
3306	MySQL	Unauthorized database access, weak credentials, SQL injection-related exposure, and data theft.

1. HTTP – Port 80

HTTP is used to access websites and web applications. It does not encrypt communication between the client and server.

- Risk: Login credentials and sensitive information may be intercepted if transmitted over HTTP.
- Possible exploitation: An attacker on the same network could capture unencrypted traffic or exploit vulnerabilities in the web application.

- Security measures:
    - Enable HTTPS using TLS certificates.
    - Redirect all HTTP requests to HTTPS.
    - Regularly update the web server and application software.
    - Use secure session cookies and web application firewalls (WAFs).

2. SSH – Port 22

SSH provides secure remote access to a system for administration.

- Risk: Weak passwords and outdated SSH software may allow unauthorized access.
- Possible exploitation: Attackers could attempt password guessing, brute-force attacks, or exploit known vulnerabilities in outdated versions.
- Security measures:
    - Use strong passwords and SSH key-based authentication.
    - Disable direct root login.
    - Disable password authentication where practical.
    - Restrict SSH access to trusted IP addresses or a VPN.
    - Enable multi-factor authentication (MFA) where supported and monitor login attempts.

3. MySQL – Port 3306

MySQL is a database management system used to store and retrieve application data.

- Risk: If exposed to untrusted networks, the database may be targeted for unauthorized access or data theft.
- Possible exploitation: An attacker may attempt to use stolen credentials, exploit a vulnerable database version, or abuse excessive database privileges.
- Security measures:
    - Do not expose MySQL directly to the public internet.
    - Restrict database access through firewalls and network segmentation.
    - Use strong credentials and least-privilege database accounts.
    - Patch MySQL regularly.
    - Enable encrypted connections and maintain secure backups.

B. How an Attacker Could Exploit the Findings

An attacker may use the scan results to identify the target's attack surface and select further tests.

1. Reconnaissance: Identify open ports, software versions, and the operating system.
2. Vulnerability identification: Compare detected versions against known security advisories.
3. Initial access attempts: Test for weak SSH credentials or vulnerable web applications.
4. Database targeting: Check whether MySQL is accessible from unauthorized networks.
5. Privilege escalation or data theft: If access is obtained, attempt to access sensitive files, database records, or administrative functions.

These are potential attack paths, not proof that the target is vulnerable. An open port alone does not establish that a service can be compromised.

C. Recommended Overall Security Measures

- Close unnecessary ports and disable unused services.
- Apply security patches to the operating system and applications.
- Configure firewalls using a default-deny approach.
- Implement network segmentation between web, database, and management systems.
- Conduct regular vulnerability assessments and authorized penetration tests.
- Enable centralized logging, intrusion detection, and security alerts.
- Follow the principle of least privilege.
- Maintain encrypted, tested, and regularly updated backups.

Conclusion

The Nmap report identifies three important entry points that require protection. HTTP needs encrypted communication, SSH requires strong remote-access controls, and MySQL should be restricted to authorized systems. A combination of patch management, firewalls, access controls, and continuous monitoring can significantly reduce the attack surface.

2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. Using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable use awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.(20 Mark).

Introduction

GoPhish is a phishing simulation tool used by security teams to evaluate employee awareness of phishing and social engineering attacks. The campaign at ABC Technologies Pvt. Ltd. revealed that 40% of employees clicked a phishing link, 20% entered their credentials, and several employees downloaded a malicious attachment.

A. Analysis of the Report

Finding	Security weakness	Possible consequence
40% clicked the phishing link	Insufficient ability to identify suspicious emails	Users may visit fraudulent websites.
20% entered login credentials	Failure to verify website authenticity	Attackers may steal accounts and passwords.
Users downloaded malicious attachments	Inadequate attachment-handling awareness	Malware infection or unauthorized access.

1. High phishing-link click rate

The 40% click rate indicates that a significant proportion of employees interacted with a potentially deceptive email.

Possible reasons include:

- Lack of phishing awareness training.
- Trust in messages that appear to come from managers or trusted organizations.
- Failure to inspect sender addresses and link destinations.
- Pressure caused by urgent or threatening messages.

2. Credential disclosure

The 20% credential-entry rate demonstrates that some employees did not recognize or adequately verify a fraudulent login page.

This could lead to:

- Account takeover.
- Unauthorized access to email and business applications.
- Business email compromise.
- Exposure of confidential company information.

- Further phishing attacks using compromised accounts.

3. Malicious attachment downloads

Downloading suspicious attachments demonstrates inadequate awareness of malware-related risks.

Possible consequences include:

- Installation of ransomware, spyware, or other malware.
- Theft of sensitive files.
- Unauthorized access to internal systems.
- Disruption of business operations.
- Malware spreading to shared resources or other systems.

The report does not establish that every downloaded attachment executed successfully or infected a device.

B. Recommended User Awareness Programs

1. Regular security awareness training

Conduct mandatory training sessions covering:

- Identifying suspicious sender addresses.
- Recognizing spelling errors, unusual requests, and urgent language.
- Checking links before opening them.
- Avoiding unexpected attachments.
- Verifying payment requests and password-reset messages independently.

2. Simulated phishing exercises

Conduct authorized GoPhish campaigns periodically using different phishing scenarios.

- Start with basic examples and gradually introduce more realistic scenarios.
- Provide immediate educational feedback when a user clicks a simulated link.
- Repeat the exercises to measure improvement.
- Identify departments that need additional support without creating a blame-based culture.

3. Reporting awareness

Train employees to report suspicious emails through a dedicated reporting button or designated security email address. Explain how to report accidental clicks, credential disclosure, or suspicious downloads immediately.

C. Recommended Email Security Controls

Control	Purpose
Secure Email Gateway	Filters spam, phishing messages, and malicious attachments.
SPF, DKIM, and DMARC	Help validate legitimate email sources and reduce domain spoofing.
Multi-Factor Authentication (MFA)	Adds another layer of protection if a password is stolen.
URL filtering	Blocks known malicious websites and phishing links.
Attachment sandboxing	Safely analyzes suspicious files before delivery.
Endpoint Detection and Response (EDR)	Detects and helps contain malicious activity on devices.
Anti-malware protection	Detects and blocks known malicious files and behavior.

D. Organizational Policies

ABC Technologies should implement the following policies:

1. Email and internet usage policy: Define safe practices for email, links, downloads, and web browsing.
2. Password policy: Require unique passwords, approved password managers, and MFA for important accounts.
3. Incident reporting policy: Require prompt reporting of suspicious emails and accidental credential disclosure.
4. Access control policy: Apply least privilege and restrict access to sensitive company resources.
5. Incident response plan: Establish procedures to isolate affected devices, reset compromised credentials, revoke active sessions, and investigate incidents.
6. Regular assessment policy: Measure phishing click rates, credential-submission rates, attachment interactions, and reporting rates over time.

E. Measuring Improvement

The organization should compare results across repeated campaigns.

For example, if the click rate decreases from 40% to 15%, this would indicate improvement in employee awareness, provided the campaigns are reasonably comparable. Credential submission and attachment interaction rates should also decrease, while the rate of suspicious-email reporting should increase.

Conclusion

The GoPhish report reveals weaknesses in phishing recognition, credential protection, and attachment handling. ABC Technologies should combine employee education, email filtering, MFA, endpoint security, incident-response procedures, and repeated phishing simulations. These measures can reduce the likelihood and impact of successful social engineering attacks.

3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure..(10 Marks)

Introduction

DNS (Domain Name System) translates domain names into IP addresses and stores information about services associated with a domain. The dig tool is used to query DNS records and diagnose DNS configuration issues.

An AXFR (Authoritative Zone Transfer) operation copies DNS zone information from one DNS server to another. The report indicates that an unauthorized or insufficiently restricted zone transfer exposed internal hostnames, mail servers, and DNS records.

A. Security Implications

1. Information disclosure

A successful unauthorized zone transfer may expose:

- Internal hostnames and server naming conventions.
- Mail servers and mail-routing records.
- Subdomains and service-related DNS records.
- IP addresses associated with organizational systems.
- DNS configuration details that reveal parts of the network architecture.

2. Increased attack surface

The disclosed records help attackers understand the organization's infrastructure and identify systems that may deserve further security assessment.

3. Targeted attacks

Attackers may use the information to:

- Identify web servers, mail servers, and administrative systems.
- Select potential targets for vulnerability scanning.
- Prepare convincing phishing messages using real organizational names.
- Discover exposed or forgotten services.
- Plan attacks against identified systems.

A successful AXFR does not itself provide access to those systems, but it makes reconnaissance easier.

B. Recommended Security Measures

1. Restrict zone transfers: Permit AXFR only to authorized secondary DNS servers.
2. Use access control lists (ACLs): Allow transfers only from approved IP addresses.
3. Implement TSIG authentication: Use Transaction Signature (TSIG) keys to authenticate DNS zone-transfer requests between authorized servers.
4. Separate internal and external DNS: Maintain split-horizon DNS where appropriate, so internal records are not exposed publicly.
5. Review DNS records: Remove obsolete hostnames and unnecessary records, and avoid publishing sensitive infrastructure details.
6. Monitor DNS activity: Log and investigate unusual zone-transfer requests.
7. Secure DNS software: Patch DNS servers regularly and apply secure configuration standards.
8. Test configurations: Conduct periodic authorized DNS security assessments to verify that unauthorized AXFR requests are rejected.

C. Conclusion

The DNS assessment identifies a configuration weakness that may expose valuable information about the organization's infrastructure. Restricting zone transfers, using ACLs and TSIG, separating internal and external DNS, and monitoring DNS activity can reduce information disclosure and make reconnaissance more difficult.